

added 45 packages in 13s

5 packages are looking for funding

run `npm fund` for details

---> Removed intermediate container 0cd7c16a4461

---> 8d9b1f7d8dff

Step 8/8 : ENTRYPOINT ["/bin/bash"]

---> Running in f693c9c60066

---> Removed intermediate container f693c9c60066

---> 15fafa661478

Successfully built 15fafa661478

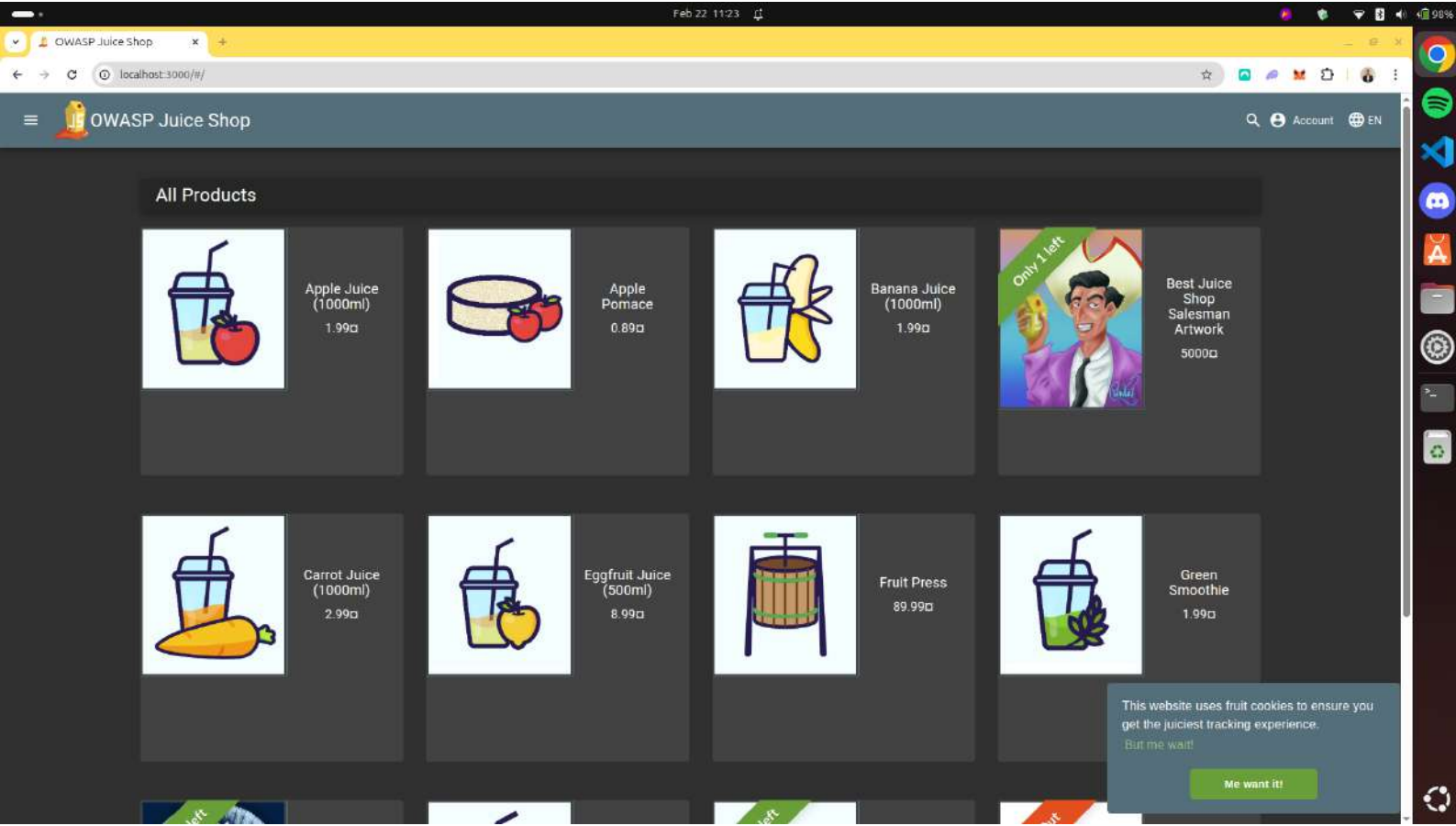
Successfully tagged ss2526-w3tb:latest

rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM: ~/SegSoftware/week3/p2\$

```
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM:~/SegSoftware/week3/p2$ docker image ls
docker ps -a
docker container prune -f
REPOSITORY      TAG          IMAGE ID      CREATED        SIZE
ss2526-w3tb     latest      15fafe661478  2 minutes ago  751MB
ubuntu          24.04       bbdabce66f1b  11 days ago   78.1MB
hello-world     latest      1b44b5a3e06a  6 months ago  10.1kB
CONTAINER ID    IMAGE        COMMAND       CREATED       STATUS       PORTS        NAMES
Total reclaimed space: 0B
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM:~/SegSoftware/week3/p2$
```

```
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM:~/SegSoftware/week3/p2$ docker pull bkimminich/juice-shop:latest
docker pull vulnerables/web-dvwa:latest
latest: Pulling from bkimminich/juice-shop
fd4aa3667332: Pull complete
bfb59b82a9b6: Pull complete
017886f7e176: Pull complete
62de241dac5f: Pull complete
2780920e5dbf: Pull complete
7c12895b777b: Pull complete
3214acf345c0: Pull complete
52630fc75a18: Pull complete
dd64bf2dd177: Pull complete
4aa0ea1413d3: Pull complete
dcaa5a89b0cc: Pull complete
069d1e267530: Pull complete
e7fa9df358f0: Pull complete
d8a0d911b13e: Pull complete
5b14f6c9a813: Pull complete
33ce0b1d99fc: Pull complete
f45e0372ce60: Pull complete
7faf0cfa885c: Pull complete
9cd2a1476fcc: Pull complete
9d2a7448ec0d: Pull complete
ea42d2577342: Pull complete
Digest: sha256:e68bd19091f952a0cdf75c5ca318d92e7a06b350ab5a88446f2bf62daf2e88c9
Status: Downloaded newer image for bkimminich/juice-shop:latest
docker.io/bkimminich/juice-shop:latest
latest: Pulling from vulnerables/web-dvwa
3e17c6eae66c: Pull complete
0c57df616dbf: Pull complete
eb05d18be401: Pull complete
e9968e5981d2: Pull complete
2cd72dba8257: Pull complete
6cff5f35147f: Pull complete
098cffd43466: Pull complete
b3d64a33242d: Pull complete
Digest: sha256:dae203fe11646a86937bf04db0079adef295f426da68a92b40e3b181f337daa7
Status: Downloaded newer image for vulnerables/web-dvwa:latest
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM:~/SegSoftware/week3/p2$
```

```
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM: ~/SegSoftware/week3/p2$ docker run -d --name juice -p 3000:3000 bkimminich/juice-shop:latest
docker ps -a
2f470e12d78372b0ae89144a204aec04135d966a26eaa9338b0691d01440aa87
CONTAINER ID   IMAGE                                COMMAND                  CREATED              STATUS              PORTS              NAMES
2f470e12d783   bkimminich/juice-shop:latest        "/nodejs/bin/node /j..." Less than a second ago Up Less than a second 0.0.0.0:3000->3000/tcp, :::3000->3000/tcp juice
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM: ~/SegSoftware/week3/p2$
```



```
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM:~/SegSoftware/week3/p2$ docker kill juice && docker rm juice
juice
juice
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM:~/SegSoftware/week3/p2$
```

```
rubensilva091@rubensilva091-ASUS-TUF-F15-FX516PM-FX516PM: /segSoftware/week3/p2$ docker run --rm -it --name toolbox -v "$PWD:/work" -v /var/run/docker.sock:/var/run/docker.sock -w /work  
ss2526-w3tb:latest  
root@9ce38c91dffb:/work#
```

/juice-shop/frontend/src/app/last-login-ip/last-login-ip.component.spec.ts (secrets)

Total: 1 (UNKNOWN: 0, LOW: 0, MEDIUM: 1, HIGH: 0, CRITICAL: 0)

MEDIUM: JWT (jwt-token)

JWT token

/juice-shop/frontend/src/app/last-login-ip/last-login-ip.component.spec.ts:61 (offset: 2220 bytes) (added by 'COPY --chown=65532:0 /juice-shop . # bui')

```
59
60     xit('should set Last-Login IP from JWT as trusted HTML', () => { // FIXME Expected state seems to
61 | ocalStorage.setItem('token', '*****')
62     component.ngOnInit()
```

/juice-shop/lib/insecurity.ts (secrets)

Total: 1 (UNKNOWN: 0, LOW: 0, MEDIUM: 0, HIGH: 1, CRITICAL: 0)

HIGH: AsymmetricPrivateKey (private-key)

Asymmetric Private Key

/juice-shop/lib/insecurity.ts:23 (offset: 860 bytes) (added by 'COPY --chown=65532:0 /juice-shop . # bui')

```
21
22 export const publicKey = fs ? fs.readFileSync('encryptionkeys/jwt.pub', 'utf8') : 'placeholder-publi
23 | ---BEGIN RSA PRIVATE KEY-----*****
*****
*****
*****-----END RSA PRIVATE
24
```

root@9ce38c91dffb:/work# █

```
root@9ce38c91dff:/work# trivy image --format cyclonedx -o trivy-juice.json bkimminich/juice-shop:latest
2026-02-22T11:27:00Z INFO --format cyclonedx disables security scanning. Specify "--scanners vuln" explicitly if you want to include vulnerabilities in the "cyclonedx" report.
2026-02-22T11:27:02Z INFO Detected OS family="debian" version="12.12"
2026-02-22T11:27:02Z INFO Number of language-specific files num=1
root@9ce38c91dff:/work#
```

```
root@9ce38c91dffb:/work# trivy image --format cyclonedx -o trivy-juice.json bkimminich/juice-shop:latest
2026-02-22T11:27:00Z INFO "--format cyclonedx" disables security scanning. Specify "--scanners vuln" explicitly if you want to include vulnerabilities in the "cyclonedx" report.
2026-02-22T11:27:02Z INFO Detected OS family="debian" version="12.12"
2026-02-22T11:27:02Z INFO Number of language-specific files num=1
root@9ce38c91dffb:/work# syft bkimminich/juice-shop:latest -o cyclonedx-json > syft-juice.json
✓ Loaded image
✓ Parsed image
✓ Cataloged contents
├── ✓ Packages [1,137 packages]
├── ✓ Executables [286 executables]
├── ✓ File metadata [2,391 locations]
└── ✓ File digests [2,391 files]
bkimminich/juice-shop:latest
sha256:6ce4baa03610d74eae5c14db6e4d73d212d40fa0ed15ada75a5f1adc7c65853
0b10e714634cb49acf9299d23433cf1ea65950e17c06733150eb47b45d2e2d15
root@9ce38c91dffb:/work#
```

```
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM: ~/SegSoftware/week3/p2$ wget https://github.com/CycloneDX/cyclonedx-cli/releases/download/v0.30.0/cyclonedx-linux-x64
chmod +x cyclonedx-linux-x64
--2026-02-22 11:31:19-- https://github.com/CycloneDX/cyclonedx-cli/releases/download/v0.30.0/cyclonedx-linux-x64
Resolving github.com (github.com)... 140.82.121.4
Connecting to github.com (github.com)|140.82.121.4|:443... connected.
HTTP request sent, awaiting response... 302 Found
Location: https://release-assets.githubusercontent.com/github-production-release-asset/306314377/f3255672-0d6c-4a14-b9c5-8c5081f02b06?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-02-22T12%3A13%3A18Z&rsct=attachment%3B+filename%3Dcyclonedx-linux-x64&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2026-02-22T11%3A12%3A48Z&ske=2026-02-22T12%3A13%3A18Z&skvs=b&skv=2018-11-09&sig=3%2BMTanJQZ6Wwadhq8jdVTPR6Ybp0jJCXU6eBS7oEMBU%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXN0YyIuY29tIiwiaXVkIjoicmVsZWZzZS1hc3NldHMuz210aHVidXNlcmNvbnRlbnQvY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc3MTc2MTY3OSwibmJmIjojNzcxNzU5ODc5LCJwYXRoIjoicmVsZWZzZWZzc2V0cHJvZHVjdGlvbi5ibG9iLmNvcnUud2luZG93cySuZXQiFQ.9r8kGtp-vW_0LVVP31gJmu2BFxkn0gA-U8DYc3-ggu4&response-content-disposition=attachment%3B%20filename%3Dcyclonedx-linux-x64&response-content-type=application%2Foctet-stream [following]
--2026-02-22 11:31:19-- https://release-assets.githubusercontent.com/github-production-release-asset/306314377/f3255672-0d6c-4a14-b9c5-8c5081f02b06?sp=r&sv=2018-11-09&sr=b&spr=https&se=2026-02-22T12%3A13%3A18Z&rsct=attachment%3B+filename%3Dcyclonedx-linux-x64&rsct=application%2Foctet-stream&skoid=96c2d410-5711-43a1-aedd-ab1947aa7ab0&sktid=398a6654-997b-47e9-b12b-9515b896b4de&skt=2026-02-22T11%3A12%3A48Z&ske=2026-02-22T12%3A13%3A18Z&skvs=b&skv=2018-11-09&sig=3%2BMTanJQZ6Wwadhq8jdVTPR6Ybp0jJCXU6eBS7oEMBU%3D&jwt=eyJ0eXAiOiJKV1QiLCJhbGciOiJIUzI1NiJ9.eyJpc3MiOiJnaXN0YyIuY29tIiwiaXVkIjoicmVsZWZzZS1hc3NldHMuz210aHVidXNlcmNvbnRlbnQvY29tIiwia2V5Ijoia2V5MSIsImV4cCI6MTc3MTc2MTY3OSwibmJmIjojNzcxNzU5ODc5LCJwYXRoIjoicmVsZWZzZWZzc2V0cHJvZHVjdGlvbi5ibG9iLmNvcnUud2luZG93cySuZXQiFQ.9r8kGtp-vW_0LVVP31gJmu2BFxkn0gA-U8DYc3-ggu4&response-content-disposition=attachment%3B%20filename%3Dcyclonedx-linux-x64&response-content-type=application%2Foctet-stream
Resolving release-assets.githubusercontent.com (release-assets.githubusercontent.com)... 185.199.108.133, 185.199.109.133, 185.199.110.133, ...
Connecting to release-assets.githubusercontent.com (release-assets.githubusercontent.com)|185.199.108.133|:443... connected.
HTTP request sent, awaiting response... 200 OK
Length: 72859283 (69M) [application/octet-stream]
Saving to: 'cyclonedx-linux-x64'

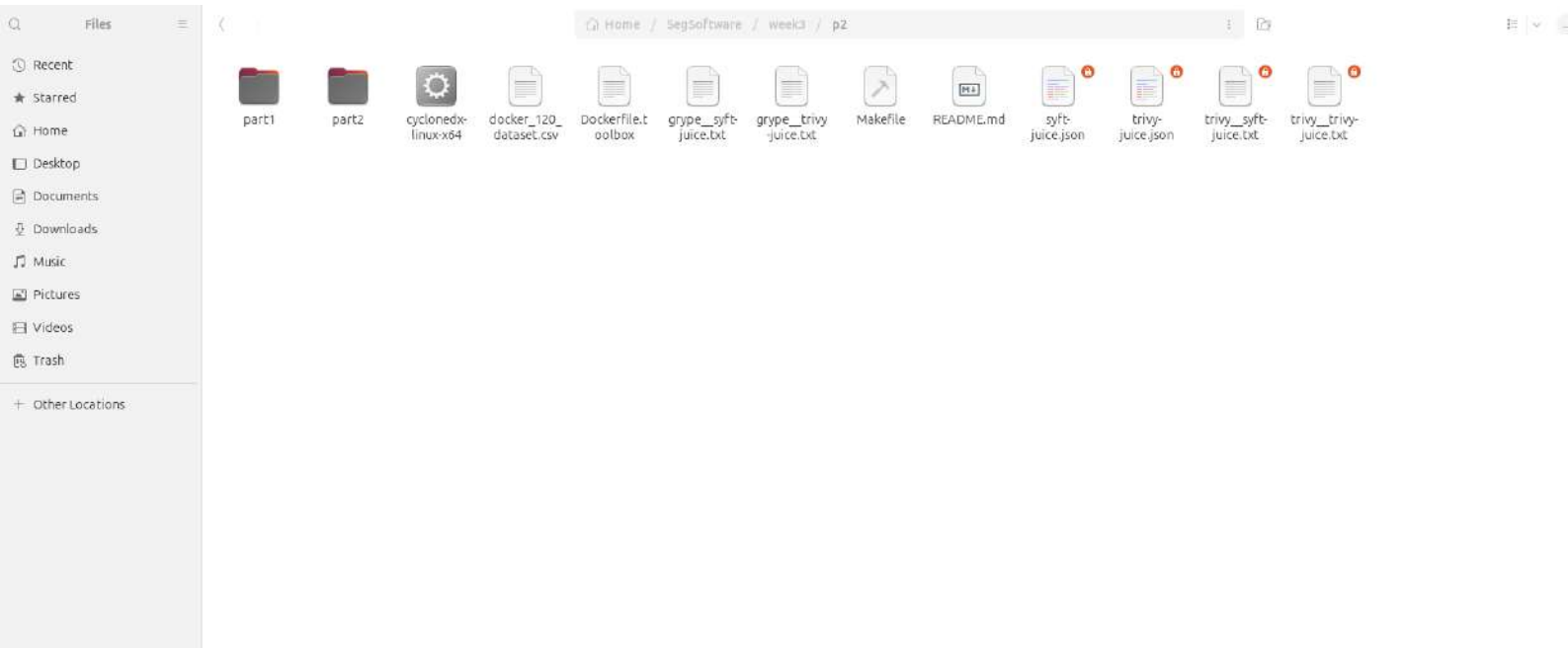
cyclonedx-linux-x64 100%[=====>] 69.48M 9.11MB/s in 8.1s

2026-02-22 11:31:28 (8.60 MB/s) - 'cyclonedx-linux-x64' saved [72859283/72859283]
```

```
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM: ~/SegSoftware/week3/p2$
```

```
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM: ~/SegSoftware/week3/p1$ ./cyclonedx-linux-x64 validate --input-file syft-juice.json
./cyclonedx-linux-x64 validate --input-file trivy-juice.json
BOM validated successfully.
BOM validated successfully.
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM: ~/SegSoftware/week3/p1$
```

```
ss2526-w3tb:latest
root@140a46cb2c0d:/work# grype sbom:syft-juice.json > grype__syft-juice.txt
grype sbom:trivy-juice.json > grype__trivy-juice.txt
trivy sbom:syft-juice.json > trivy__syft-juice.txt
trivy sbom:trivy-juice.json > trivy__trivy-juice.txt
✓ Vulnerability DB [updated]
✓ Scanned for vulnerabilities [109 vulnerability matches]
└─ by severity: 11 critical, 55 high, 28 medium, 3 low, 12 negligible
   by status: 89 fixed, 20 not-fixed, 0 ignored
✓ Scanned for vulnerabilities [80 vulnerability matches]
└─ by severity: 9 critical, 45 high, 23 medium, 3 low, 0 negligible
   by status: 75 fixed, 5 not-fixed, 0 ignored
2026-02-22T11:35:14Z INFO [vulndb] Need to update DB
2026-02-22T11:35:14Z INFO [vulndb] Downloading vulnerability DB...
2026-02-22T11:35:14Z INFO [vulndb] Downloading artifact... repo="mirror.gcr.io/aquasec/trivy-db:2"
86.04 MiB / 86.04 MiB [-----] 100.00% 7.53 MiB p/s 12s
2026-02-22T11:35:26Z INFO [vulndb] Artifact successfully downloaded repo="mirror.gcr.io/aquasec/trivy-db:2"
2026-02-22T11:35:26Z INFO [vuln] Vulnerability scanning is enabled
2026-02-22T11:35:26Z INFO Detected SBOM format format="cyclonedx-json"
2026-02-22T11:35:26Z WARN Third-party SBOM may lead to inaccurate vulnerability detection
2026-02-22T11:35:26Z WARN Recommend using Trivy to generate SBOMs
2026-02-22T11:35:26Z INFO Detected OS family="debian" version="12"
2026-02-22T11:35:26Z INFO [debian] Detecting vulnerabilities... os_version="12" pkg_num=10
2026-02-22T11:35:26Z INFO Number of language-specific files num=1
2026-02-22T11:35:26Z INFO [node-pkg] Detecting vulnerabilities...
2026-02-22T11:35:26Z INFO [vuln] Vulnerability scanning is enabled
2026-02-22T11:35:26Z INFO Detected SBOM format format="cyclonedx-json"
2026-02-22T11:35:26Z INFO Detected OS family="debian" version="12.12"
2026-02-22T11:35:26Z INFO [debian] Detecting vulnerabilities... os_version="12" pkg_num=10
2026-02-22T11:35:26Z INFO Number of language-specific files num=1
2026-02-22T11:35:26Z INFO [node-pkg] Detecting vulnerabilities...
2026-02-22T11:35:26Z WARN Using severities from other vendors for some vulnerabilities. Read https://trivy.dev/docs/v0.69/guide/scanner/vulnerability#severity-selection for details.
2026-02-22T11:35:26Z INFO Table result includes only package filenames. Use '--format json' option to get the full path to the package file.
root@140a46cb2c0d:/work#
```



NAME:

osv-scanner - scans various mediums for dependencies and checks them against the OSV database

USAGE:

osv-scanner [global options] command [command options]

EXAMPLES:

Scan a source directory

\$ osv-scanner scan source -r <source_directory>

Scan a source directory in offline mode

\$ osv-scanner scan source --offline-vulnerabilities --download-offline-database -r <source_directory>

Scan a container image

\$ osv-scanner scan image <image_name>

Scan a local image archive (e.g. a tar file) and generate HTML output

\$ osv-scanner scan image --serve --archive <image_name.tar>

Fix vulnerabilities in a manifest file and lockfile (non-interactive mode)

\$ osv-scanner fix -M <manifest_file> -L <lockfile>

For full usage details, please refer to the help command of each subcommand (e.g. osv-scanner scan --help).

Alternatively, you can access the detailed documentation here: <https://google.github.io/osv-scanner/>

VERSION:

2.3.3

COMMANDS:

scan	scans projects and container images for dependencies, and checks them against the OSV database.
fix	scans a manifest and/or lockfile for vulnerabilities and suggests changes for remediating them
experimental-mcp	Run osv-scanner as an MCP service (experimental)

GLOBAL OPTIONS:

--help, -h show help --version, -v print the version

rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM: ~/SegSoftware/week3/p2\$

```
rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM: ~/SegSoftware/week3/p2

7 uncalled/unimportant vulnerabilities found in os:/var/lib/dpkg/status.d/libc6 (filtered out)

os:/var/lib/dpkg/status.d/libgcc-s1: found 0 packages with issues

gcc-12@12.2.0-14+deb12u1 (binary package: libgcc-s1) has the following unimportant vulnerabilities:
  introduced in # 16 Layer (cc)
  DEBIAN-CVE-2022-27943: libiberty/rust-demangle.c in GNU GCC 11.2 allows stack consumption in...
    Severity: '5.5'; Minimal Fix Version: 'No fix available';

1 uncalled/unimportant vulnerability found in os:/var/lib/dpkg/status.d/libgcc-s1 (filtered out)

os:/var/lib/dpkg/status.d/libgomp1: found 0 packages with issues

gcc-12@12.2.0-14+deb12u1 (binary package: libgomp1) has the following unimportant vulnerabilities:
  introduced in # 14 Layer (cc)
  DEBIAN-CVE-2022-27943: libiberty/rust-demangle.c in GNU GCC 11.2 allows stack consumption in...
    Severity: '5.5'; Minimal Fix Version: 'No fix available';

1 uncalled/unimportant vulnerability found in os:/var/lib/dpkg/status.d/libgomp1 (filtered out)

os:/var/lib/dpkg/status.d/libssl3: found 1 package with issues

openssl@3.0.17-1-deb12u3 (binary package: libssl3) has the following known vulnerabilities:
  introduced in # 13 Layer (base)
  OSA-6113-1: openssl - security update
    Severity: '9.8'; Minimal Fix Version: '3.0.18-1-deb12u2';

1 known vulnerability found in os:/var/lib/dpkg/status.d/libssl3

openssl@3.0.17-1-deb12u3 (binary package: libssl3) has the following unimportant vulnerabilities:
  introduced in # 13 Layer (base)
  DEBIAN-CVE-2025-27587: OpenSSL 3.0.0 through 3.3.2 on the PowerPC architecture is vulnerable to a...
    Severity: '5.3'; Minimal Fix Version: 'No fix available';

1 uncalled/unimportant vulnerability found in os:/var/lib/dpkg/status.d/libssl3 (filtered out)

os:/var/lib/dpkg/status.d/libstdc++6: found 0 packages with issues

gcc-12@12.2.0-14+deb12u1 (binary package: libstdc++6) has the following unimportant vulnerabilities:
  introduced in # 15 Layer (cc)
  DEBIAN-CVE-2022-27943: libiberty/rust-demangle.c in GNU GCC 11.2 allows stack consumption in...
    Severity: '5.5'; Minimal Fix Version: 'No fix available';

1 uncalled/unimportant vulnerability found in os:/var/lib/dpkg/status.d/libstdc++6 (filtered out)

rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM: ~/SegSoftware/week3/p2$
```

```
● rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM:~/SegSoftware/week3/p2$ python3 scan_csv.py
.....
A verificar se a imagem existe: nginx:latest
A imagem 'nginx:latest' existe no Docker Hub.
A gerar SBOM com o Trivy...
2026-02-22T12:02:30Z INFO      "--format cyclonedx" disables security scanning. Specify "--scanners vuln" explicitly if you want to include vulnerabilities in the CycloneDX report.
2026-02-22T12:02:39Z INFO      Java DB Repository      repository=ghcr.io/aquasecurity/trivy-java-db:1
2026-02-22T12:02:39Z INFO      Downloading the Java DB...
830.52 MiB / 830.52 MiB [-----] 100.00% 6.29 MiB p/s 2m12s
2026-02-22T12:04:54Z INFO      The Java DB is cached for 3 days. If you want to update the database more frequently, the '--reset' flag clears the DB cache.
2026-02-22T12:04:54Z INFO      Detected OS      family="debian" version="13.3"
2026-02-22T12:04:54Z INFO      Number of language-specific files      num=0
SBOM guardado como: sbom_nginx_latest.json
● rubensilva091@rubensilva091-ASUS-TUF-Dash-F15-FX516PM-FX516PM:~/SegSoftware/week3/p2$
```